E-Carnet — Inventaire juridique à soumettre au juriste

Audit textuel du dépôt e-carnet v1 · 8 octobre 2026 · Document de travail, non constitutif d'un avis juridique

Objet : recenser les textes, règles, engagements, formulations sensibles et décisions métier visibles ou codées dans le projet afin qu'un juriste puisse les corriger, compléter, supprimer ou valider. Aucune formulation ci-dessous ne doit être considérée comme juridiquement approuvée.

1. Périmètre de l'audit

- Dépôt complet e-carnet v1 (429 entrées), avec inspection des sources applicatives, modèles Django, pages Next.js, composants UI et documentation.
- Sources particulièrement sensibles : docs/CONDITIONS-RATTACHEMENT-MEDECIN.md, docs/SECURITY.md, docs/QUESTIONNAIRE-DECISIONS-A1-A16.md, docs/ETAT-REEL-V1.md, docs/FLOW-ETABLISSEMENT.md, docs/RECETTE-V1.md, docs/GO-NO-GO-2026-10-05.md.
- Pages publiques : /a-propos, /securite, /faq, /conditions-rattachement.
- Parcours concernés : inscription, identité, profil professionnel, rattachement établissement/médecin, demandes d'accès, QR, consentement, consultation, historique, paramètres et sécurité.
- Les éléments techniques (statuts, enums, durées, scopes, événements d'audit) sont également listés lorsqu'ils ont une conséquence juridique ou contractuelle potentielle.

2. Textes contractuels / engagements à faire valider

Source principale : docs/CONDITIONS-RATTACHEMENT-MEDECIN.md + apps/web/src/app/conditions-rattachement/page.tsx.

1. 1. Protéger les informations non publiques de l'établissement auxquelles le médecin accède et ne pas les divulguer à des personnes non autorisées, sauf obligation légale ou autorisation documentée.
2. 2. Préserver la confidentialité des patients et n'accéder à leurs informations que dans le cadre de sa mission, avec les autorisations et consentements exigés par le service.
3. 3. Saisir des informations médicales de bonne foi et exactes, distinguer les déclarations du patient des constatations professionnelles, et ne pas inventer, altérer ou falsifier un diagnostic, une consultation, une attestation ou un dossier.
4. 4. Protéger ses moyens d'accès, ne pas transmettre son compte, son mot de passe ou ses codes personnels et signaler toute compromission présumée.
5. 5. L'établissement peut mettre fin au rattachement et le médecin peut également y mettre fin depuis son espace privé ; la fin du rattachement bloque les nouveaux accès cliniques dépendant de cette affiliation.
6. 6. La fin du rattachement n'efface pas les événements d'audit ni les documents et consultations déjà constitués ; leur conservation et leur accès ultérieur restent soumis aux règles légales, à la politique de conservation à approuver et aux contrôles d'accès applicables.
7. 7. L'acceptation enregistre l'identifiant du médecin, l'établissement, l'identifiant du rattachement, la version des conditions, la date et l'heure UTC et l'événement d'audit correspondant.
8. 8. Sans acceptation explicite de la version applicable, le code n'est pas consommé et aucune demande de rattachement n'est créée.
9. 9. L'acceptation ne confère aucun accès automatique à un dossier patient ; le rattachement doit être approuvé par l'établissement et chaque accès clinique reste conditionné aux autorisations professionnelles, aux périmètres permis et au consentement requis du patient.

3. Mentions et avertissements juridiques déjà présents

Emplacement	Formulation repérée	Point à faire examiner
Écran Conditions	« Projet fonctionnel à faire valider par un conseil juridique avant tout usage contractuel réel. Ce texte ne remplace pas le contrat complet entre l'établissement et le médecin. »	Validation de la formulation et du niveau de réserve.
Conditions	« L'identité des parties, les responsabilités, la durée, les exceptions de confidentialité, les règles de conservation, la signature électronique et les exigences locales doivent être validées par un juriste avant production. »	Compléter les notions et références légales.
Sécurité	« Ce document décrit le code et ses limites. Il ne constitue ni une certification, ni une garantie de conformité, ni un audit indépendant. »	Définir les mentions publiques autorisées.
Sécurité publique	« La V1 reste un pilote sur données fictives. L'hébergement ivoirien, la revue juridique, la restauration testée et les contrôles indépendants sont obligatoires avant toute donnée réelle. »	Vérifier promesse, conditions et vocabulaire.
Onboarding professionnel	« E-Carnet ne vérifie pas les justificatifs médicaux et ne demande ici aucun numéro professionnel. L'établissement effectue ses vérifications en interne ; l'application enregistre ensuite sa décision de rattachement. »	À confronter aux obligations locales.
Profil professionnel	« La spécialité est déclarée par vous. Les justificatifs médicaux ne sont pas collectés par E-Carnet : leur vérification relève de l'établissement. »	Clarifier responsabilité et portée de la vérification.
À propos	« Un professionnel ne lit rien sans vérification, rattachement, établissement actif et consentement explicite. »	Valider la précision « ne lit rien » et les exceptions.
FAQ	« Il doit être vérifié, être rattaché à un établissement actif et recevoir votre autorisation temporaire. »	Définir exactement ce que signifie « vérifié ».

4. Données personnelles, données de santé et droits — sujets à formaliser

- Déterminer le responsable du traitement, les éventuels sous-traitants, leurs rôles et les coordonnées à afficher.
- Déterminer les finalités de chaque catégorie : compte, authentification, profil, rattachement, pré-consultation, déclarations, consultations, accès temporaires, audit, sécurité, support et obligations légales.
- Qualifier juridiquement les données de santé et les autres catégories particulières présentes dans le carnet.

- Définir la base juridique de chaque traitement, les conditions de consentement lorsque celui-ci est utilisé, et la différence entre consentement au traitement et autorisation d'accès clinique.
- Définir les durées de conservation : dossier, consultation, audit, rattachement, invitations, codes, preuves de structure, journaux techniques, comptes et sauvegardes.
- Définir les règles de rectification, opposition, accès, export/portabilité, suppression, limitation et éventuelles exceptions liées à l'historique/audit.
- Définir la politique applicable aux corrections de données médicales : qui peut corriger, comment l'ancienne valeur est conservée, et quelle preuve est produite.
- Définir les règles de traitement des comptes supprimés ou désactivés et leurs effets sur l'historique.
- Définir les transferts internationaux éventuels liés à l'hébergement, aux sauvegardes, à l'e-mail, OAuth, analytics éventuels et prestataires.
- Formaliser la politique cookies/traceurs si de futurs outils marketing ou analytics sont ajoutés.
- Formaliser la procédure d'exercice des droits et le canal de contact.
- Formaliser la gestion des mineurs, représentants légaux, personnes vulnérables et situations d'aide à la pré-consultation.
- Définir la procédure d'incident : qualification, responsable, délais, seuils, confinement, preuve et notifications.
- Faire confirmer les exigences ivoiriennes applicables aux données de santé et aux traitements numériques avant toute donnée réelle.

5. Consentement, autorisation et accès clinique

- Le produit distingue l'autorisation temporaire d'accès (`AccessGrant`) du rattachement professionnel à un établissement.
- Le professionnel doit disposer d'un rattachement actif et d'un établissement actif avant les actions cliniques.
- Une autorisation d'accès patient est temporaire et peut être révoquée.
- Durée active prévue : 2 heures, avec au maximum 2 prolongations d'une heure ; à faire confirmer juridiquement et médicalement.
- Le périmètre V1 par défaut est `preconsultation` + `declarations`; `consultations` est sélectionnable ; `documents` est hors V1.
- Le QR d'initiation est opaque, à usage unique, sans donnée médicale, et valable 5 minutes.
- Le texte et l'UI doivent clairement distinguer : demande d'accès, autorisation, accès actif, expiration, révocation et refus.
- Vérifier si l'expression « consentement explicite du patient » est juridiquement exacte pour chaque usage et chaque pays d'exploitation.

6. Rattachement établissement ↔ médecin

- Établissement : preuves envoyées par e-mail à l'équipe E-Carnet ; un staff vérifie dans une route privée puis crée un compte administrateur nominatif.
- Administrateur établissement : compte nominatif, associé à une structure ; peut être remplacé sans recréer la structure.
- Invitation administrateur : 48 h, une utilisation, consommation/expiration invalide le lien.
- Code de rattachement médecin : 48 h, une utilisation ; sa saisie crée seulement une demande `pending`.
- L'établissement accepte ou refuse le rattachement.
- Le médecin peut initier la fin du rattachement ; l'établissement peut également y mettre fin.
- Le départ ne doit pas effacer silencieusement l'historique.
- À faire valider : pouvoir du signataire, responsabilités, relation avec contrat de travail/prestation, sanctions, litiges, signature électronique, durée et confidentialité.

7. Sécurité : formulations à ne pas transformer en promesses

- Session serveur Django ; cookie HttpOnly ; Secure hors DEBUG ; CSRF/CORS configurés ; aucun JWT dans localStorage.
- Argon2 comme premier hash de mot de passe, avec PBKDF2 conservé pour migration.
- OAuth Google/Facebook/Apple présent dans le code mais non considéré comme validé en production.
- Audit append-only des transitions sensibles, avec limites de protection PostgreSQL encore à vérifier.
- Les données du pilote sont fictives ; aucune donnée clinique réelle avant validations et Go/No-Go.
- Les tests de restauration, RPO/RTO, staging, Android/4G, accessibilité, rate limits et revue indépendante restent des prérequis.
- Ne pas employer « sécurisé », « certifié », « conforme », « inviolable », « garanti » ou équivalent sans validation juridique et technique documentée.

8. États / enums métier ayant une portée à valider

Domaine	Valeurs codées	Libellés actuels / enjeu
Pré-consultation	draft / closed	Brouillon / Clôturée
Autorisation patient	pending / active / refused / expired / revoked	En attente / Active / Refusée / Expirée / Révoquée
Établissement	pending / active / rejected	En attente / Active / Refusée
Administrateur établissement	active / revoked / ended	Actif / Révoqué / Terminé
Rattachement médecin	pending / active / refused / suspended / terminated	En attente / Active / Refusée / Suspendue / Terminée
Profil professionnel	pending / verified / rejected	À vérifier / Vérifié / Refusé
Déclaration clinique	declared / cancelled	Déclaré par le patient / Annulé avec historique
Type de déclaration	antecedent / allergy / treatment	Antécédent / Allergie / Traitement
Rôles de contexte	patient / professional / establishment	Patient / Professionnel / Établissement
Fournisseurs OAuth	google / facebook / apple	Google / Facebook / Apple

Point particulier : « Vérifié » pour un professionnel doit être défini précisément. Le code indique que la vérification est faite en interne par l'établissement et que le statut est déclaratif côté application. Le juriste doit valider le vocabulaire public afin d'éviter toute promesse de certification par E-Carnet.

9. Décisions ouvertes A1–A16 à transformer en décisions juridiques/produit

ID	Sujet	État à faire valider
A1	OTP WhatsApp	Exclu V1 ; confirmer qu'aucune formulation publique ne laisse penser qu'il existe.
A2	Authentification	E-mail/mot de passe + Google/Facebook/Apple ; liaison explicite ; vérifier information et responsabilité des fournisseurs.
A3	Récupération/MFA	MFA/TOTP V3 ; règles de récupération encore à préciser.
A4	Structure / établissement	Justificatifs par e-mail ; vérification staff ; rétention des pièces à formaliser.
A5	Accès clinique administrateur	Aucun accès clinique via l'espace établissement en V1.
A6	Validation médecin	Pas de justificatifs personnels envoyés à E-Carnet ; vérification interne établissement ; code 48

		h.
A7	Aide pré-consultation	Pas de compte infirmier ; règles de la personne aidante à confirmer.
A8	Champs pré-consultation	Ouvert médicalement : champs, unités, bornes, obligatoires/facultatifs, antécédents/documents.
A9	Scopes / QR	QR opaque, 5 min, usage unique ; scopes V1 définis.
A10	Champs consultation	Ouvert médicalement ; corrections après validation à cadrer.
A11	Documents	Pas d'upload de justificatifs personnels médecin ; justificatifs structure reçus par e-mail ; sécurité/rétention à formaliser.
A12	Infrastructure	Vercel/Render/Neon ; région, contrats, copies, sauvegardes et sous-traitance à vérifier.
A13	Hébergement ivoirien	À choisir/vérifier avant données réelles.
A14	Droit local	Avis écrit du juriste requis.
A15	Conservation / correction / export / suppression	Durées et exceptions à approuver.
A16	Incidents / notifications	Responsables, seuils, délais, confinement et notification à définir.

10. Textes UI complémentaires à vérifier

Écran	**Texte / promesse à examiner**
Connexion	« Votre santé, votre carnet, votre décision. » / « gardez la maîtrise de vos données et gérez vos accès médicaux avec clarté. »
Authentification	« Une identité unique. Des accès temporaires, visibles et révocables. »
Profil professionnel	« E-Carnet ne vérifie pas les justificatifs médicaux… »
Compte	« Vous contrôlez votre identité, vos méthodes de connexion et vos autorisations. »
Professionnel	« Aucun dossier patient n'est accessible depuis ici. »
Établissement	« L'administrateur gère les rattachements. Il ne consulte pas les dossiers médicaux. »
FAQ	« Un professionnel voit-il mon carnet automatiquement ? Non. »
FAQ	« Vous pouvez révoquer à tout moment. »
Sécurité	« Chaque demande sensible est contrôlée côté serveur… »
À propos	« Le patient conserve ses déclarations, leur provenance et la décision d'autoriser ou non un accès. »

11. Livrable attendu du juriste

Pour chaque item, demander un retour sous l'un des statuts :

- CONSERVER — formulation validée ou acceptable.

- MODIFIER — fournir le texte de remplacement final.
- RETIRER — préciser le risque ou la raison.
- DÉPLACER — indiquer la page/document approprié.
- DÉCISION REQUISE — préciser l'information ou l'arbitrage manquant.

Demander également : textes finaux de politique de confidentialité, conditions d'utilisation, conditions de rattachement, information/consentement, politique de conservation, procédure d'exercice des droits, mentions éditeur/hébergeur/sous-traitants et procédure d'incident, selon le périmètre réellement retenu.

12. Sources principales inspectées

- docs/CONDITIONS-RATTACHEMENT-MEDECIN.md
- docs/SECURITY.md
- docs/QUESTIONNAIRE-DECISIONS-A1-A16.md
- docs/ETAT-REEL-V1.md
- docs/FLOW-ETABLISSEMENT.md
- docs/RECETTE-V1.md
- docs/GO-NO-GO-2026-10-05.md
- apps/web/src/app/conditions-rattachement/page.tsx
- apps/web/src/app/securite/page.tsx
- apps/web/src/app/faq/page.tsx
- apps/web/src/app/a-propos/page.tsx
- apps/web/src/app/connexion/page.tsx
- apps/web/src/app/inscription/page.tsx
- apps/web/src/components/ProfessionalOnboarding.tsx
- apps/web/src/components/ProfessionalSettingsClient.tsx
- apps/web/src/components/AccountSettingsClient.tsx
- apps/web/src/components/ClinicalGate.tsx
- apps/web/src/components/EstablishmentHelp.tsx
- apps/api/apps/care/models.py
- apps/api/apps/establishments/models.py
- apps/api/apps/patients/models.py
- apps/api/apps/professionals/models.py
- apps/api/apps/identity/models.py